

# Audit Package

System Security Plan, Bill of Materials, and traceability of record  
for contract **NV012**

---

## NON-EVIDENTIARY

This package was produced from mock, demonstration data. It shows exactly what a real submission looks like end to end, but it is not itself a submittable government package.

**SPRS score** 110 · Final · valid submission: True

**Controls** 110 of 110 met

**Signature** ed25519-v1 · key d8ec6f0eb4804b95

**Manifest hash** 9b95cc6513b680bd365c6888abd1d8a953d68a7cf3f1d72103fef3415b14e705

Re-verify offline with `uv run ce verify-package`.

## What this report says

---

**This self-assessment is complete and structurally valid. The contractor scores 110 on the SPRS scale and met 110 of the 110 controls required by this contract.**

Of the 110 controls, **108** are backed by an automated technical check that an assessor can re-run for themselves, and **2** rest on documented human judgment — policy, training, personnel and physical controls that no software can measure. That split is expected: roughly a third of NIST 800-171 is inherently a matter of process, not configuration.

No control was signed off as met while its automated check said otherwise, so there are no unexplained overrides to review. The run also followed its documented standard operating procedure with no deviations.

### WHAT "NON-EVIDENTIARY" MEANS

This particular package was built from mock demonstration data, so it cannot be submitted to the government. Everything below is real in structure — the scoring, the signatures, the verification steps all work exactly as they would on a live package — but the underlying evidence is fixtures, not a real system.

### IN ONE LINE

This document is a plain-language rendering of a cryptographically signed package. Nothing here has to be taken on trust: the last section shows how any reader can re-check every number offline with a single command.

## How to read this report

---

A few terms recur throughout. In plain language:

### Control

One specific security requirement from NIST SP 800-171 — for example, "lock the screen after inactivity" or "keep audit logs." There are 110 in all; this contract requires a defined subset.

### SPRS score

The single number the Department of Defense uses to summarize a self-assessment. It starts at 110 and subtracts a weight (1, 3, or 5) for each control not met. A higher number is better; 110 is a perfect score.

### Met / not met

A control is recorded as *met* only when its evidence passed the check for it *and* a named, authorized person signed off. Anything short of both is *not met*.

### Machine-verified vs. human-attested

Some controls can be proven by software re-reading system configuration (machine-verified). Others — training, policy, personnel — can only be confirmed by a person reviewing documents (human-attested). Both are legitimate; they differ in how an assessor re-checks them.

### Attested, machine-backed

A middle ground for the policy controls: a person signs off, but the document they are vouching for is *machine-recorded* — the engine resolved the actual file, fingerprinted it (SHA-256), captured the git commit that produced it, and holds a signed receipt of its upload. So the human judgment is anchored to a specific, traceable version of a real document rather than a bare "trust me."

### Override

A control marked met even though its automated check failed. This is allowed, but it must carry a written justification and supporting evidence, and it is flagged for review.

### Signed / verifiable

The whole package is sealed with a digital signature and every file is fingerprinted. If anyone changes a single character after signing, re-verification fails. That is what lets a reader trust this report without trusting whoever produced it.

## The score

The SPRS score is computed over the 110 controls this contract requires. Each control carries a weight of 1, 3, or 5 reflecting how much it matters to protecting controlled information; the score is 110 minus the weights of the controls not met. A valid submission additionally means no high-weight control was left open on a plan of action where the rules forbid it.

|                                 |                                      |                                      |                                  |                                   |
|---------------------------------|--------------------------------------|--------------------------------------|----------------------------------|-----------------------------------|
| <b>110</b><br>SPRS SCORE        | <b>Final</b><br>SUBMISSION<br>STATUS | <b>True</b><br>STRUCTURALLY<br>VALID | <b>110 / 110</b><br>CONTROLS MET | <b>108 / 2</b><br>MACHINE / HUMAN |
| <b>0</b><br>OVERRIDES TO REVIEW |                                      |                                      |                                  |                                   |

These figures are read directly from the signed manifest and are reproduced, control by control, in Appendix A.

## How each control was verified

NIST 800-171 groups its controls into fourteen families — access control, audit, incident response, and so on. The table below rolls the required controls up by family. Three ways a control earns its "met": **machine** (a configuration check the assessor can re-run), **attested, machine-backed** (a person signs off on a document the engine resolved, hashed, and captured a git commit + signed upload receipt for), and **human-attested** (rests on human judgment

with no machine artifact). Of the required controls, 65 are machine-verified, 43 are attested and machine-backed, and 2 rest on human judgment alone. Full detail is in Appendix A.

| Family                                    | Controls | Met | Machine | Attested + backed | Human-only |
|-------------------------------------------|----------|-----|---------|-------------------|------------|
| 3.1 Access Control                        | 22       | 22  | 17      | 5                 | 0          |
| 3.2 Awareness and Training                | 3        | 3   | 0       | 3                 | 0          |
| 3.3 Audit and Accountability              | 9        | 9   | 7       | 2                 | 0          |
| 3.4 Configuration Management              | 9        | 9   | 8       | 1                 | 0          |
| 3.5 Identification and Authentication     | 11       | 11  | 11      | 0                 | 0          |
| 3.6 Incident Response                     | 3        | 3   | 0       | 3                 | 0          |
| 3.7 Maintenance                           | 6        | 6   | 1       | 5                 | 0          |
| 3.8 Media Protection                      | 9        | 9   | 1       | 8                 | 0          |
| 3.9 Personnel Security                    | 2        | 2   | 0       | 2                 | 0          |
| 3.10 Physical Protection                  | 6        | 6   | 0       | 4                 | 2          |
| 3.11 Risk Assessment                      | 3        | 3   | 1       | 2                 | 0          |
| 3.12 Security Assessment                  | 4        | 4   | 0       | 4                 | 0          |
| 3.13 System and Communications Protection | 16       | 16  | 12      | 4                 | 0          |
| 3.14 System and Information Integrity     | 7        | 7   | 7       | 0                 | 0          |

## Integrity and verification

Nothing in this report has to be taken on faith. Every file in the package is fingerprinted with a SHA-256 hash, and the manifest that lists those fingerprints is sealed with a digital signature. To re-check the record, an assessor does not have to trust whoever produced it — they re-hash each file, confirm it matches the manifest, and verify the signature. If a single byte changed after signing, that check fails.

### VERIFY IT YOURSELF

Run `uv run ce verify-package` against this package. It re-hashes every artifact, checks the manifest signature, and walks the chain from each control to the signed policy behind it — entirely offline.

**Manifest signature:** ed25519-v1, key d8ec6f0eb4804b95

**Manifest hash (SHA-256):** 9b95cc6513b680bd365c6888abd1d8a953d68a7cf3f1d72103fef3415b14e705

## Bundled artifacts

The files sealed in this package, each addressable by its hash:

### Artifact      SHA-256 fingerprint

|          |                                                                  |
|----------|------------------------------------------------------------------|
| bom.json | 8a822fd0127777ae1490fc37f063b923225b41129cf730c5ebeeeead2a7139fb |
|----------|------------------------------------------------------------------|

**Artifact     SHA-256 fingerprint**

|        |                                                               |
|--------|---------------------------------------------------------------|
| ssp.md | 14a7602c192a20efba8ddb310184065aa8f55d30fc30c8976b53a54d659a2 |
|--------|---------------------------------------------------------------|

## Provenance

Beyond the final numbers, the package records *how* it was produced. The whole lineage — from the contract, to the obligations it imposes, to the required controls, the signed order, the evidence collected, the automated checks, the human sign-offs, and the resulting plan and bill of materials — is captured as a provenance graph and checked against the standard operating procedure. This is what lets an assessor confirm the record was assembled the way it was supposed to be, not just that the end state looks right.

**Standard-operating-procedure check:** passed

**Steps executed:** Apply, AttestCOP, Attestation, Audit, CollectEvidence, EmitOrder, ExtractObligations, FetchByHash, Gate1, LoadOrder, Oracles, Plan, PolicyCheck, ResolveControls, SignAndStore

The run followed its documented procedure with no deviations.

## Contradictions and overrides

There are none. Every control recorded as met either passed its automated check or had no automated check to disagree with, so no human sign-off contradicts the machine evidence.

## Appendix A — Control-by-control detail

Evidence backing: **machine** = sign-off backed by a passing config check over resolvable evidence; **attested-evidenced** = a human sign-off backed by a machine-recorded document (resolved, SHA-256 hashed, git commit + signed upload receipt) — the "Reference" column shows the reference and the commit that produced it; **override** = met over a failed check (requires written justification and appended evidence); **human-only** = no machine artifact, rests on human judgment.

| Control                   | Status | Backing            | Automated check | Attestation | Reference @ commit                  |
|---------------------------|--------|--------------------|-----------------|-------------|-------------------------------------|
| <b>3.1 Access Control</b> |        |                    |                 |             |                                     |
| AC.L2-3.1.1               | MET    | machine            | passed          | passed      | —                                   |
| AC.L2-3.1.10              | MET    | machine            | passed          | passed      | —                                   |
| AC.L2-3.1.11              | MET    | machine            | passed          | passed      | —                                   |
| AC.L2-3.1.12              | MET    | machine            | passed          | passed      | —                                   |
| AC.L2-3.1.13              | MET    | machine            | passed          | passed      | —                                   |
| AC.L2-3.1.14              | MET    | machine            | passed          | passed      | —                                   |
| AC.L2-3.1.15              | MET    | attested-evidenced | passed          | passed      | REF_POL_AC_RemoteAuth_v1 @ 84462979 |
| AC.L2-3.1.16              | MET    | machine            | passed          | passed      | —                                   |
| AC.L2-3.1.17              | MET    | machine            | passed          | passed      | —                                   |

| Control      | Status | Backing            | Automated check | Attestation | Reference @ commit                   |
|--------------|--------|--------------------|-----------------|-------------|--------------------------------------|
| AC.L2-3.1.18 | MET    | machine            | passed          | passed      | —                                    |
| AC.L2-3.1.19 | MET    | machine            | passed          | passed      | —                                    |
| AC.L2-3.1.2  | MET    | machine            | passed          | passed      | —                                    |
| AC.L2-3.1.20 | MET    | machine            | passed          | passed      | —                                    |
| AC.L2-3.1.21 | MET    | attested-evidenced | passed          | passed      | REF_POL_AC_RemoteAuth_v1 @ 84462979  |
| AC.L2-3.1.22 | MET    | attested-evidenced | passed          | passed      | REF_POL_AC_RemoteAuth_v1 @ 84462979  |
| AC.L2-3.1.3  | MET    | machine            | passed          | passed      | —                                    |
| AC.L2-3.1.4  | MET    | attested-evidenced | passed          | passed      | REF_POL_AC_SoD_v1 @ 84462979         |
| AC.L2-3.1.5  | MET    | machine            | passed          | passed      | —                                    |
| AC.L2-3.1.6  | MET    | machine            | passed          | passed      | —                                    |
| AC.L2-3.1.7  | MET    | machine            | passed          | passed      | —                                    |
| AC.L2-3.1.8  | MET    | machine            | passed          | passed      | —                                    |
| AC.L2-3.1.9  | MET    | attested-evidenced | passed          | passed      | REF_POL_AC_LoginBanner_v1 @ 84462979 |

### 3.10 Physical Protection

|              |     |                    |        |        |                                   |
|--------------|-----|--------------------|--------|--------|-----------------------------------|
| PE.L2-3.10.1 | MET | human-only         | —      | passed | —                                 |
| PE.L2-3.10.2 | MET | human-only         | —      | passed | —                                 |
| PE.L2-3.10.3 | MET | attested-evidenced | passed | passed | REF_POL_PE_Physical_v1 @ 84462979 |
| PE.L2-3.10.4 | MET | attested-evidenced | passed | passed | REF_POL_PE_Physical_v1 @ 84462979 |
| PE.L2-3.10.5 | MET | attested-evidenced | passed | passed | REF_POL_PE_Physical_v1 @ 84462979 |
| PE.L2-3.10.6 | MET | attested-evidenced | passed | passed | REF_POL_PE_Physical_v1 @ 84462979 |

### 3.11 Risk Assessment

|              |     |                    |        |        |                                     |
|--------------|-----|--------------------|--------|--------|-------------------------------------|
| RA.L2-3.11.1 | MET | attested-evidenced | passed | passed | REF_POL_RA_Assessment_v1 @ 84462979 |
| RA.L2-3.11.2 | MET | machine            | passed | passed | —                                   |
| RA.L2-3.11.3 | MET | attested-evidenced | passed | passed | REF_POL_RA_Assessment_v1 @ 84462979 |

### 3.12 Security Assessment

|              |     |                    |        |        |                                     |
|--------------|-----|--------------------|--------|--------|-------------------------------------|
| CA.L2-3.12.1 | MET | attested-evidenced | passed | passed | REF_POL_CA_Monitoring_v1 @ 84462979 |
| CA.L2-3.12.2 | MET | attested-evidenced | passed | passed | REF_POL_CA_Monitoring_v1 @ 84462979 |
| CA.L2-3.12.3 | MET | attested-evidenced | passed | passed | REF_POL_CA_Monitoring_v1 @ 84462979 |
| CA.L2-3.12.4 | MET | attested-evidenced | passed | passed | REF_POL_SSP_v1 @ 84462979           |

### 3.13 System and Communications Protection

|              |     |         |        |        |   |
|--------------|-----|---------|--------|--------|---|
| SC.L2-3.13.1 | MET | machine | passed | passed | — |
|--------------|-----|---------|--------|--------|---|

| Control       | Status | Backing            | Automated check | Attestation | Reference @ commit              |
|---------------|--------|--------------------|-----------------|-------------|---------------------------------|
| SC.L2-3.13.10 | MET    | machine            | passed          | passed      | —                               |
| SC.L2-3.13.11 | MET    | machine            | passed          | passed      | —                               |
| SC.L2-3.13.12 | MET    | attested-evidenced | passed          | passed      | REF_POL_SC_Collab_v1 @ 84462979 |
| SC.L2-3.13.13 | MET    | attested-evidenced | passed          | passed      | REF_POL_SC_Collab_v1 @ 84462979 |
| SC.L2-3.13.14 | MET    | attested-evidenced | passed          | passed      | REF_POL_SC_Collab_v1 @ 84462979 |
| SC.L2-3.13.15 | MET    | machine            | passed          | passed      | —                               |
| SC.L2-3.13.16 | MET    | machine            | passed          | passed      | —                               |
| SC.L2-3.13.2  | MET    | attested-evidenced | passed          | passed      | REF_POL_SC_SecEng_v1 @ 84462979 |
| SC.L2-3.13.3  | MET    | machine            | passed          | passed      | —                               |
| SC.L2-3.13.4  | MET    | machine            | passed          | passed      | —                               |
| SC.L2-3.13.5  | MET    | machine            | passed          | passed      | —                               |
| SC.L2-3.13.6  | MET    | machine            | passed          | passed      | —                               |
| SC.L2-3.13.7  | MET    | machine            | passed          | passed      | —                               |
| SC.L2-3.13.8  | MET    | machine            | passed          | passed      | —                               |
| SC.L2-3.13.9  | MET    | machine            | passed          | passed      | —                               |

### 3.14 System and Information Integrity

|              |     |         |        |        |   |
|--------------|-----|---------|--------|--------|---|
| SI.L2-3.14.1 | MET | machine | passed | passed | — |
| SI.L2-3.14.2 | MET | machine | passed | passed | — |
| SI.L2-3.14.3 | MET | machine | passed | passed | — |
| SI.L2-3.14.4 | MET | machine | passed | passed | — |
| SI.L2-3.14.5 | MET | machine | passed | passed | — |
| SI.L2-3.14.6 | MET | machine | passed | passed | — |
| SI.L2-3.14.7 | MET | machine | passed | passed | — |

### 3.2 Awareness and Training

|             |     |                    |        |        |                                   |
|-------------|-----|--------------------|--------|--------|-----------------------------------|
| AT.L2-3.2.1 | MET | attested-evidenced | passed | passed | REF_POL_AT_Training_v1 @ 84462979 |
| AT.L2-3.2.2 | MET | attested-evidenced | passed | passed | REF_POL_AT_Training_v1 @ 84462979 |
| AT.L2-3.2.3 | MET | attested-evidenced | passed | passed | REF_POL_AT_Training_v1 @ 84462979 |

### 3.3 Audit and Accountability

|             |     |                    |        |        |                                    |
|-------------|-----|--------------------|--------|--------|------------------------------------|
| AU.L2-3.3.1 | MET | machine            | passed | passed | —                                  |
| AU.L2-3.3.2 | MET | machine            | passed | passed | —                                  |
| AU.L2-3.3.3 | MET | attested-evidenced | passed | passed | REF_POL_AU_Procedure_v1 @ 84462979 |
| AU.L2-3.3.4 | MET | machine            | passed | passed | —                                  |

| Control     | Status | Backing            | Automated check | Attestation | Reference @ commit                 |
|-------------|--------|--------------------|-----------------|-------------|------------------------------------|
| AU.L2-3.3.5 | MET    | machine            | passed          | passed      | —                                  |
| AU.L2-3.3.6 | MET    | attested-evidenced | passed          | passed      | REF_POL_AU_Procedure_v1 @ 84462979 |
| AU.L2-3.3.7 | MET    | machine            | passed          | passed      | —                                  |
| AU.L2-3.3.8 | MET    | machine            | passed          | passed      | —                                  |
| AU.L2-3.3.9 | MET    | machine            | passed          | passed      | —                                  |

### 3.4 Configuration Management

|             |     |                    |        |        |                                 |
|-------------|-----|--------------------|--------|--------|---------------------------------|
| CM.L2-3.4.1 | MET | machine            | passed | passed | —                               |
| CM.L2-3.4.2 | MET | machine            | passed | passed | —                               |
| CM.L2-3.4.3 | MET | machine            | passed | passed | —                               |
| CM.L2-3.4.4 | MET | attested-evidenced | passed | passed | REF_POL_CM_Config_v1 @ 84462979 |
| CM.L2-3.4.5 | MET | machine            | passed | passed | —                               |
| CM.L2-3.4.6 | MET | machine            | passed | passed | —                               |
| CM.L2-3.4.7 | MET | machine            | passed | passed | —                               |
| CM.L2-3.4.8 | MET | machine            | passed | passed | —                               |
| CM.L2-3.4.9 | MET | machine            | passed | passed | —                               |

### 3.5 Identification and Authentication

|              |     |         |        |        |   |
|--------------|-----|---------|--------|--------|---|
| IA.L2-3.5.1  | MET | machine | passed | passed | — |
| IA.L2-3.5.10 | MET | machine | passed | passed | — |
| IA.L2-3.5.11 | MET | machine | passed | passed | — |
| IA.L2-3.5.2  | MET | machine | passed | passed | — |
| IA.L2-3.5.3  | MET | machine | passed | passed | — |
| IA.L2-3.5.4  | MET | machine | passed | passed | — |
| IA.L2-3.5.5  | MET | machine | passed | passed | — |
| IA.L2-3.5.6  | MET | machine | passed | passed | — |
| IA.L2-3.5.7  | MET | machine | passed | passed | — |
| IA.L2-3.5.8  | MET | machine | passed | passed | — |
| IA.L2-3.5.9  | MET | machine | passed | passed | — |

### 3.6 Incident Response

|             |     |                    |        |        |                               |
|-------------|-----|--------------------|--------|--------|-------------------------------|
| IR.L2-3.6.1 | MET | attested-evidenced | passed | passed | REF_POL_IR_Plan_v1 @ 84462979 |
| IR.L2-3.6.2 | MET | attested-evidenced | passed | passed | REF_POL_IR_Plan_v1 @ 84462979 |
| IR.L2-3.6.3 | MET | attested-evidenced | passed | passed | REF_POL_IR_Plan_v1 @ 84462979 |



| Control                       | Status | Backing            | Automated check | Attestation | Reference @ commit                   |
|-------------------------------|--------|--------------------|-----------------|-------------|--------------------------------------|
| <b>3.7 Maintenance</b>        |        |                    |                 |             |                                      |
| MA.L2-3.7.1                   | MET    | attested-evidenced | passed          | passed      | REF_POL_MA_Maintenance_v1 @ 84462979 |
| MA.L2-3.7.2                   | MET    | attested-evidenced | passed          | passed      | REF_POL_MA_Maintenance_v1 @ 84462979 |
| MA.L2-3.7.3                   | MET    | attested-evidenced | passed          | passed      | REF_POL_MA_Maintenance_v1 @ 84462979 |
| MA.L2-3.7.4                   | MET    | attested-evidenced | passed          | passed      | REF_POL_MA_Maintenance_v1 @ 84462979 |
| MA.L2-3.7.5                   | MET    | machine            | passed          | passed      | —                                    |
| MA.L2-3.7.6                   | MET    | attested-evidenced | passed          | passed      | REF_POL_MA_Maintenance_v1 @ 84462979 |
| <b>3.8 Media Protection</b>   |        |                    |                 |             |                                      |
| MP.L2-3.8.1                   | MET    | attested-evidenced | passed          | passed      | REF_POL_MP_Media_v1 @ 84462979       |
| MP.L2-3.8.2                   | MET    | attested-evidenced | passed          | passed      | REF_POL_MP_Media_v1 @ 84462979       |
| MP.L2-3.8.3                   | MET    | attested-evidenced | passed          | passed      | REF_POL_MP_Media_v1 @ 84462979       |
| MP.L2-3.8.4                   | MET    | attested-evidenced | passed          | passed      | REF_POL_MP_Media_v1 @ 84462979       |
| MP.L2-3.8.5                   | MET    | attested-evidenced | passed          | passed      | REF_POL_MP_Media_v1 @ 84462979       |
| MP.L2-3.8.6                   | MET    | attested-evidenced | passed          | passed      | REF_POL_MP_Media_v1 @ 84462979       |
| MP.L2-3.8.7                   | MET    | machine            | passed          | passed      | —                                    |
| MP.L2-3.8.8                   | MET    | attested-evidenced | passed          | passed      | REF_POL_MP_Media_v1 @ 84462979       |
| MP.L2-3.8.9                   | MET    | attested-evidenced | passed          | passed      | REF_POL_MP_Media_v1 @ 84462979       |
| <b>3.9 Personnel Security</b> |        |                    |                 |             |                                      |
| PS.L2-3.9.1                   | MET    | attested-evidenced | passed          | passed      | REF_POL_PS_Personnel_v1 @ 84462979   |
| PS.L2-3.9.2                   | MET    | attested-evidenced | passed          | passed      | REF_POL_PS_Personnel_v1 @ 84462979   |

## Appendix B — Signed-policy inventory

The authoritative source documents behind the attested (policy) controls. Each resolves to a version-pinned artifact and is checked for freshness and a role-appropriate signature.

| Reference                         | Source          | Version                                                          | Signature |
|-----------------------------------|-----------------|------------------------------------------------------------------|-----------|
| REF_POL_<br>AC_Login<br>Banner_v1 | AUTHSRC_DocRepo | f8899a4f032f1cace69f666903cd25ca3962adc0f8c1b71e79b9c8bd268cf085 | signed    |
| REF_POL_<br>AC_Remot<br>eAuth_v1  | AUTHSRC_DocRepo | e72ac1c82bac4a12f4f40dd1f34742735f70b4c202cad3c3884a0d8c3f158796 | signed    |
| REF_POL_<br>AC_SoD_v1             | AUTHSRC_DocRepo | 999cec0bfcd05236ca3756db65624a72ed395ef3a6994f9d3cf266981f720113 | signed    |

| Reference                         | Source                | Version                                                          | Signature |
|-----------------------------------|-----------------------|------------------------------------------------------------------|-----------|
| REF_POL_<br>AT_Train<br>ing_v1    | AUTHSRC_LMS           | 180dde084fb16478a30290be831ebf3981dca349959cb6784a78ce8807261f2e | signed    |
| REF_POL_<br>AU_Proce<br>dure_v1   | AUTHSRC_DocRepo       | 36c4d7355280f4230f67d23aaf3e90e79551c19727faad9169971887a9bcd333 | signed    |
| REF_POL_<br>CA_Monit<br>oring_v1  | AUTHSRC_EngineHistory | 8f21848dc6379e97a94f8a7ab57398eff0f79e70c263890f95eb6ae32c1e5a9a | signed    |
| REF_POL_<br>CM_Confi<br>g_v1      | AUTHSRC_DocRepo       | ae495c9b8f2c0e81e94149adf9c42bfbf85cbe7a91dd4b14c544d9a15440fc77 | signed    |
| REF_POL_<br>IR_Plan_<br>v1        | AUTHSRC_DocRepo       | ef2f0ed929c198a8f27a0db8dcab61d2d026438c2590d7f9cfb26a934ab50dae | signed    |
| REF_POL_<br>MA_Maint<br>enance_v1 | AUTHSRC_DocRepo       | eb35fb9a5824185a5f88571035735c8a938dbbb56877a3d689d215c9e21ea393 | signed    |
| REF_POL_<br>MP_Media_<br>v1       | AUTHSRC_DocRepo       | a89a3c0e2b297354d49d0d041e5ef8944dfb372f9a123a882066e0cd7c13e695 | signed    |
| REF_POL_<br>PE_Physi<br>cal_v1    | AUTHSRC_DocRepo       | 06cb72f393a6d46393c940a23246d506bd6ec24a6bf2dbdfec61e312603e5b3c | signed    |
| REF_POL_<br>PS_Perso<br>nnel_v1   | AUTHSRC_HRIS          | 19b16764e49d14e6f6942d1c7dc1b950610bba5aef75b5ba8f21c185c8955516 | signed    |
| REF_POL_<br>RA_Asses<br>sment_v1  | AUTHSRC_DocRepo       | a9a40a16b2050da39e04747b60a7e0a3615657eb0e4a80e692c4926057364b84 | signed    |
| REF_POL_<br>SC_Colla<br>b_v1      | AUTHSRC_DocRepo       | 3572f47e4ecf05277025cef3e09c53d476027908054dc2f4e7a30fe47775db52 | signed    |
| REF_POL_<br>SC_SecEn<br>g_v1      | AUTHSRC_DocRepo       | bd099d38da87e0823280b1478fd84354a7fdbf99b967652d990582cf1be663d5 | signed    |
| REF_POL_<br>SSP_v1                | AUTHSRC_DocRepo       | a24a3a009e50c11885add90a6b7e2c2134ba648e4042bb18a9c327be73b4884a | signed    |

## Appendix C — Full control catalog (all 110)

The complete NIST SP 800-171 Rev. 2 catalog and how each control is verified in the model: 65 machine-verified, 43 attested-reference, 2 CSP-inherited. "In this order" marks the controls this contract requires and scores above; the rest are out of scope for this order.

| Control          | Wt | Verified by        | In this order | Requirement                                                                         |
|------------------|----|--------------------|---------------|-------------------------------------------------------------------------------------|
| AC.L2-3.1.1      | 5  | Machine-verified   | yes           | Limit system access to authorized users, processes acting on behalf of authorize... |
| AC.L2-3.1.1<br>0 | 1  | Machine-verified   | yes           | Use session lock with pattern-hiding displays to prevent access and viewing of d... |
| AC.L2-3.1.1<br>1 | 1  | Machine-verified   | yes           | Terminate (automatically) a user session after a defined condition.                 |
| AC.L2-3.1.1<br>2 | 5  | Machine-verified   | yes           | Monitor and control remote access sessions.                                         |
| AC.L2-3.1.1<br>3 | 5  | Machine-verified   | yes           | Employ cryptographic mechanisms to protect the confidentiality of remote access ... |
| AC.L2-3.1.1<br>4 | 1  | Machine-verified   | yes           | Route remote access via managed access control points.                              |
| AC.L2-3.1.1<br>5 | 1  | Attested-reference | yes           | Authorize remote execution of privileged commands and remote access to security-... |
| AC.L2-3.1.1<br>6 | 5  | Machine-verified   | yes           | Authorize wireless access prior to allowing such connections.                       |
| AC.L2-3.1.1<br>7 | 5  | Machine-verified   | yes           | Protect wireless access using authentication and encryption.                        |
| AC.L2-3.1.1<br>8 | 5  | Machine-verified   | yes           | Control connection of mobile devices.                                               |
| AC.L2-3.1.1<br>9 | 3  | Machine-verified   | yes           | Encrypt CUI on mobile devices and mobile computing platforms.                       |
| AC.L2-3.1.2      | 5  | Machine-verified   | yes           | Limit system access to the types of transactions and functions that authorized u... |
| AC.L2-3.1.2<br>0 | 1  | Machine-verified   | yes           | Verify and control/limit connections to and use of external systems.                |
| AC.L2-3.1.2<br>1 | 1  | Attested-reference | yes           | Limit use of portable storage devices on external systems.                          |
| AC.L2-3.1.2<br>2 | 1  | Attested-reference | yes           | Control CUI posted or processed on publicly accessible systems.                     |
| AC.L2-3.1.3      | 1  | Machine-verified   | yes           | Control the flow of CUI in accordance with approved authorizations.                 |
| AC.L2-3.1.4      | 1  | Attested-reference | yes           | Separate the duties of individuals to reduce the risk of malevolent activity wit... |

| Control      | Wt | Verified by        | In this order | Requirement                                                                         |
|--------------|----|--------------------|---------------|-------------------------------------------------------------------------------------|
| AC.L2-3.1.5  | 3  | Machine-verified   | yes           | Employ the principle of least privilege, including for specific security functio... |
| AC.L2-3.1.6  | 1  | Machine-verified   | yes           | Use non-privileged accounts or roles when accessing nonsecurity functions.          |
| AC.L2-3.1.7  | 1  | Machine-verified   | yes           | Prevent non-privileged users from executing privileged functions and capture the... |
| AC.L2-3.1.8  | 1  | Machine-verified   | yes           | Limit unsuccessful logon attempts.                                                  |
| AC.L2-3.1.9  | 1  | Attested-reference | yes           | Provide privacy and security notices consistent with applicable CUI rules.          |
| AT.L2-3.2.1  | 5  | Attested-reference | yes           | Ensure that managers, systems administrators, and users of organizational system... |
| AT.L2-3.2.2  | 5  | Attested-reference | yes           | Ensure that personnel are trained to carry out their assigned information securi... |
| AT.L2-3.2.3  | 1  | Attested-reference | yes           | Provide security awareness training on recognizing and reporting potential indic... |
| AU.L2-3.3.1  | 5  | Machine-verified   | yes           | Create and retain system audit logs and records to the extent needed to enable t... |
| AU.L2-3.3.2  | 3  | Machine-verified   | yes           | Ensure that the actions of individual system users can be uniquely traced to tho... |
| AU.L2-3.3.3  | 1  | Attested-reference | yes           | Review and update logged events.                                                    |
| AU.L2-3.3.4  | 1  | Machine-verified   | yes           | Alert in the event of an audit logging process failure.                             |
| AU.L2-3.3.5  | 5  | Machine-verified   | yes           | Correlate audit record review, analysis, and reporting processes for investigati... |
| AU.L2-3.3.6  | 1  | Attested-reference | yes           | Provide audit record reduction and report generation to support on-demand analys... |
| AU.L2-3.3.7  | 1  | Machine-verified   | yes           | Provide a system capability that compares and synchronizes internal system clock... |
| AU.L2-3.3.8  | 1  | Machine-verified   | yes           | Protect audit information and audit logging tools from unauthorized access, modi... |
| AU.L2-3.3.9  | 1  | Machine-verified   | yes           | Limit management of audit logging functionality to a subset of privileged users.    |
| CA.L2-3.12.1 | 5  | Attested-reference | yes           | Periodically assess the security controls in organizational systems to determine... |
| CA.L2-3.12.2 | 3  | Attested-reference | yes           | Develop and implement plans of action designed to correct deficiencies and reduc... |

| Control      | Wt | Verified by        | In this order | Requirement                                                                            |
|--------------|----|--------------------|---------------|----------------------------------------------------------------------------------------|
| CA.L2-3.12.3 | 5  | Attested-reference | yes           | Monitor security controls on an ongoing basis to ensure the continued effectiveness... |
| CA.L2-3.12.4 | 1  | Attested-reference | yes           | Develop, document, and periodically update system security plans that describe s...    |
| CM.L2-3.4.1  | 5  | Machine-verified   | yes           | Establish and maintain baseline configurations and inventories of organizational...    |
| CM.L2-3.4.2  | 5  | Machine-verified   | yes           | Establish and enforce security configuration settings for information technology...    |
| CM.L2-3.4.3  | 1  | Machine-verified   | yes           | Track, review, approve or disapprove, and log changes to organizational systems.       |
| CM.L2-3.4.4  | 1  | Attested-reference | yes           | Analyze the security impact of changes prior to implementation.                        |
| CM.L2-3.4.5  | 5  | Machine-verified   | yes           | Define, document, approve, and enforce physical and logical access restrictions ...    |
| CM.L2-3.4.6  | 5  | Machine-verified   | yes           | Employ the principle of least functionality by configuring organizational system...    |
| CM.L2-3.4.7  | 5  | Machine-verified   | yes           | Restrict, disable, or prevent the use of nonessential programs, functions, ports...    |
| CM.L2-3.4.8  | 5  | Machine-verified   | yes           | Apply deny-by-exception (blacklisting) policy to prevent the use of unauthorized...    |
| CM.L2-3.4.9  | 1  | Machine-verified   | yes           | Control and monitor user-installed software.                                           |
| IA.L2-3.5.1  | 5  | Machine-verified   | yes           | Identify system users, processes acting on behalf of users, and devices.               |
| IA.L2-3.5.10 | 5  | Machine-verified   | yes           | Store and transmit only cryptographically-protected passwords.                         |
| IA.L2-3.5.11 | 1  | Machine-verified   | yes           | Obscure feedback of authentication information.                                        |
| IA.L2-3.5.2  | 5  | Machine-verified   | yes           | Authenticate (or verify) the identities of users, processes, or devices, as a pr...    |
| IA.L2-3.5.3  | 5  | Machine-verified   | yes           | Use multifactor authentication for local and network access to privileged accoun...    |
| IA.L2-3.5.4  | 1  | Machine-verified   | yes           | Employ replay-resistant authentication mechanisms for network access to privileg...    |
| IA.L2-3.5.5  | 1  | Machine-verified   | yes           | Prevent reuse of identifiers for a defined period.                                     |
| IA.L2-3.5.6  | 1  | Machine-verified   | yes           | Disable identifiers after a defined period of inactivity.                              |

| Control     | Wt | Verified by        | In this order | Requirement                                                                         |
|-------------|----|--------------------|---------------|-------------------------------------------------------------------------------------|
| IA.L2-3.5.7 | 1  | Machine-verified   | yes           | Enforce a minimum password complexity and change of characters when new password... |
| IA.L2-3.5.8 | 1  | Machine-verified   | yes           | Prohibit password reuse for a specified number of generations.                      |
| IA.L2-3.5.9 | 1  | Machine-verified   | yes           | Allow temporary password use for system logons with an immediate change to a per... |
| IR.L2-3.6.1 | 5  | Attested-reference | yes           | Establish an operational incident-handling capability for organizational systems... |
| IR.L2-3.6.2 | 5  | Attested-reference | yes           | Track, document, and report incidents to designated officials and/or authorities... |
| IR.L2-3.6.3 | 1  | Attested-reference | yes           | Test the organizational incident response capability.                               |
| MA.L2-3.7.1 | 3  | Attested-reference | yes           | Perform maintenance on organizational systems.                                      |
| MA.L2-3.7.2 | 5  | Attested-reference | yes           | Provide controls on the tools, techniques, mechanisms, and personnel used to con... |
| MA.L2-3.7.3 | 1  | Attested-reference | yes           | Ensure equipment removed for off-site maintenance is sanitized of any CUI.          |
| MA.L2-3.7.4 | 3  | Attested-reference | yes           | Check media containing diagnostic and test programs for malicious code before th... |
| MA.L2-3.7.5 | 5  | Machine-verified   | yes           | Require multifactor authentication to establish nonlocal maintenance sessions vi... |
| MA.L2-3.7.6 | 1  | Attested-reference | yes           | Supervise the maintenance activities of maintenance personnel without required a... |
| MP.L2-3.8.1 | 3  | Attested-reference | yes           | Protect (i.e., physically control and securely store) system media containing CU... |
| MP.L2-3.8.2 | 3  | Attested-reference | yes           | Limit access to CUI on system media to authorized users.                            |
| MP.L2-3.8.3 | 5  | Attested-reference | yes           | Sanitize or destroy system media containing CUI before disposal or release for r... |
| MP.L2-3.8.4 | 1  | Attested-reference | yes           | Mark media with necessary CUI markings and distribution limitations.                |
| MP.L2-3.8.5 | 1  | Attested-reference | yes           | Control access to media containing CUI and maintain accountability for media dur... |
| MP.L2-3.8.6 | 1  | Attested-reference | yes           | Implement cryptographic mechanisms to protect the confidentiality of CUI stored ... |
| MP.L2-3.8.7 | 5  | Machine-verified   | yes           | Control the use of removable media on system components.                            |

| Control       | Wt | Verified by        | In this order | Requirement                                                                         |
|---------------|----|--------------------|---------------|-------------------------------------------------------------------------------------|
| MP.L2-3.8.8   | 3  | Attested-reference | yes           | Prohibit the use of portable storage devices when such devices have no identifia... |
| MP.L2-3.8.9   | 1  | Attested-reference | yes           | Protect the confidentiality of backup CUI at storage locations.                     |
| PE.L2-3.10.1  | 5  | CSP-inherited      | yes           | Limit physical access to organizational systems, equipment, and the respective o... |
| PE.L2-3.10.2  | 5  | CSP-inherited      | yes           | Protect and monitor the physical facility and support infrastructure for organiz... |
| PE.L2-3.10.3  | 1  | Attested-reference | yes           | Escort visitors and monitor visitor activity.                                       |
| PE.L2-3.10.4  | 1  | Attested-reference | yes           | Maintain audit logs of physical access.                                             |
| PE.L2-3.10.5  | 1  | Attested-reference | yes           | Control and manage physical access devices.                                         |
| PE.L2-3.10.6  | 1  | Attested-reference | yes           | Enforce safeguarding measures for CUI at alternate work sites.                      |
| PS.L2-3.9.1   | 3  | Attested-reference | yes           | Screen individuals prior to authorizing access to organizational systems contain... |
| PS.L2-3.9.2   | 5  | Attested-reference | yes           | Ensure that organizational systems containing CUI are protected during and after... |
| RA.L2-3.11.1  | 3  | Attested-reference | yes           | Periodically assess the risk to organizational operations (including mission, fu... |
| RA.L2-3.11.2  | 5  | Machine-verified   | yes           | Scan for vulnerabilities in organizational systems and applications periodically... |
| RA.L2-3.11.3  | 1  | Attested-reference | yes           | Remediate vulnerabilities in accordance with risk assessments.                      |
| SC.L2-3.13.1  | 5  | Machine-verified   | yes           | Monitor, control, and protect communications (i.e., information transmitted or r... |
| SC.L2-3.13.10 | 1  | Machine-verified   | yes           | Establish and manage cryptographic keys for cryptography employed in organizatio... |
| SC.L2-3.13.11 | 5  | Machine-verified   | yes           | Employ FIPS-validated cryptography when used to protect the confidentiality of C... |
| SC.L2-3.13.12 | 1  | Attested-reference | yes           | Prohibit remote activation of collaborative computing devices and provide indica... |
| SC.L2-3.13.13 | 1  | Attested-reference | yes           | Control and monitor the use of mobile code.                                         |
| SC.L2-3.13.14 | 1  | Attested-reference | yes           | Control and monitor the use of Voice over Internet Protocol (VoIP) technologies.    |

| Control       | Wt | Verified by        | In this order | Requirement                                                                         |
|---------------|----|--------------------|---------------|-------------------------------------------------------------------------------------|
| SC.L2-3.13.15 | 5  | Machine-verified   | yes           | Protect the authenticity of communications sessions.                                |
| SC.L2-3.13.16 | 1  | Machine-verified   | yes           | Protect the confidentiality of CUI at rest.                                         |
| SC.L2-3.13.2  | 5  | Attested-reference | yes           | Employ architectural designs, software development techniques, and systems engin... |
| SC.L2-3.13.3  | 1  | Machine-verified   | yes           | Separate user functionality from system management functionality.                   |
| SC.L2-3.13.4  | 1  | Machine-verified   | yes           | Prevent unauthorized and unintended information transfer via shared system resou... |
| SC.L2-3.13.5  | 5  | Machine-verified   | yes           | Implement subnetworks for publicly accessible system components that are physica... |
| SC.L2-3.13.6  | 5  | Machine-verified   | yes           | Deny network communications traffic by default and allow network communications ... |
| SC.L2-3.13.7  | 1  | Machine-verified   | yes           | Prevent remote devices from simultaneously establishing non-remote connections w... |
| SC.L2-3.13.8  | 3  | Machine-verified   | yes           | Implement cryptographic mechanisms to prevent unauthorized disclosure of CUI dur... |
| SC.L2-3.13.9  | 1  | Machine-verified   | yes           | Terminate network connections associated with communications sessions at the end... |
| SI.L2-3.14.1  | 5  | Machine-verified   | yes           | Identify, report, and correct system flaws in a timely manner.                      |
| SI.L2-3.14.2  | 5  | Machine-verified   | yes           | Provide protection from malicious code at designated locations within organizati... |
| SI.L2-3.14.3  | 5  | Machine-verified   | yes           | Monitor system security alerts and advisories and take action in response.          |
| SI.L2-3.14.4  | 5  | Machine-verified   | yes           | Update malicious code protection mechanisms when new releases are available.        |
| SI.L2-3.14.5  | 3  | Machine-verified   | yes           | Perform periodic scans of organizational systems and real-time scans of files fr... |
| SI.L2-3.14.6  | 5  | Machine-verified   | yes           | Monitor organizational systems, including inbound and outbound communications tr... |
| SI.L2-3.14.7  | 3  | Machine-verified   | yes           | Identify unauthorized use of organizational systems.                                |

This report renders the signed audit-package manifest. The manifest is the source of truth; this document is a human rendering of it. Re-verify with `uv run ce verify-package`.